HACK THE BOX · MACHINE WRITEUP

Keeper



Default creds on a Request Tracker instance leak a KeePass backup. CVE-2023-32784 recovers the master password from a memory dump

Linux | Easy | Default Creds | Keepass | CVE | Password Cracking

Made with **SysReptor**



10.10.11.227
Target IP

gugeldot
Author

2025-05-29
Date

KEEPER · WALKTHROUGH

Contents

01 General information 3

1.1 Executive summary 3

1.2 Kill chain 3

02 Reconnaissance 4

03 Foothold 4

04 Privilege escalation 6

05 Flags 8

06 Notes & lessons 8

07 References 8

1. General information

Default creds on a Request Tracker instance leak a KeePass backup. CVE-2023-32784 recovers the master password from a memory dump

PLATFORM	Hack The Box
SYSTEM	Linux
DIFFICULTY	Easy
IP	`10.10.11.227`
TAGS	`Default Creds` `Keepass` `CVE` `Password Cracking`
CVES	`CVE-2023-32784`

1.1 Executive summary

Keeper is a Linux machine running **Request Tracker** (RT) with a default administrator account still enabled. The RT admin panel's Users list leaks the initial password for a helpdesk account, valid over SSH and giving the user flag along with a ZIP backup of a KeePass password manager, including a process memory dump. CVE-2023-32784 recovers almost all of the KeePass master password straight from that memory dump, and a Danish-language clue in the user's RT profile resolves the remaining characters to a well-known Danish phrase, which unlocks a stored PuTTY-format private key for root.

1.2 Kill chain

1. The `tickets.keeper.htb` vhost runs **Request Tracker** (RT) with the well-known **default credentials** (`root:password`).
2. Logged in as the RT admin, the **Admin > Users** panel exposes an entry for `lnorgaard` (a Danish helpdesk agent) whose comments field leaks her initial password in plaintext: `Welcome2023!`.
3. SSH access with `lnorgaard:Welcome2023!` gives the user flag and surfaces a ZIP backup of a KeePass password manager (`.kdbx` database plus a captured process memory dump, `KeePassDumpFull.dmp`).

4. CVE-2023-32784 (KeePass < 2.54 leaves nearly the entire master password recoverable from process memory) is run against the dump with `keepass-password-dumper`, reconstructing all but the first two characters of the master password.
5. The RT profile's Danish-language flag points to the well-known Danish tongue-twister **`rødgrød med fløde`**, which matches every recovered candidate and completes the master password.
6. The recovered master password unlocks the KeePass database, which stores a **PuTTY-format** private key for `root` in a `keeper.htb (Ticketing Server)` entry.
7. The key is converted to OpenSSH format (`puttygen`) and used to SSH in directly as root: root flag.

2. Reconnaissance

Port scan

```
sudo nmap --open -Pn -sS --min-rate 2500 -p- 10.10.11.227
```

Results:

```
22/tcp open  ssh
80/tcp open  http
```

Service & version scan

```
nmap -sCV --open -p<ports> 10.10.11.227
```

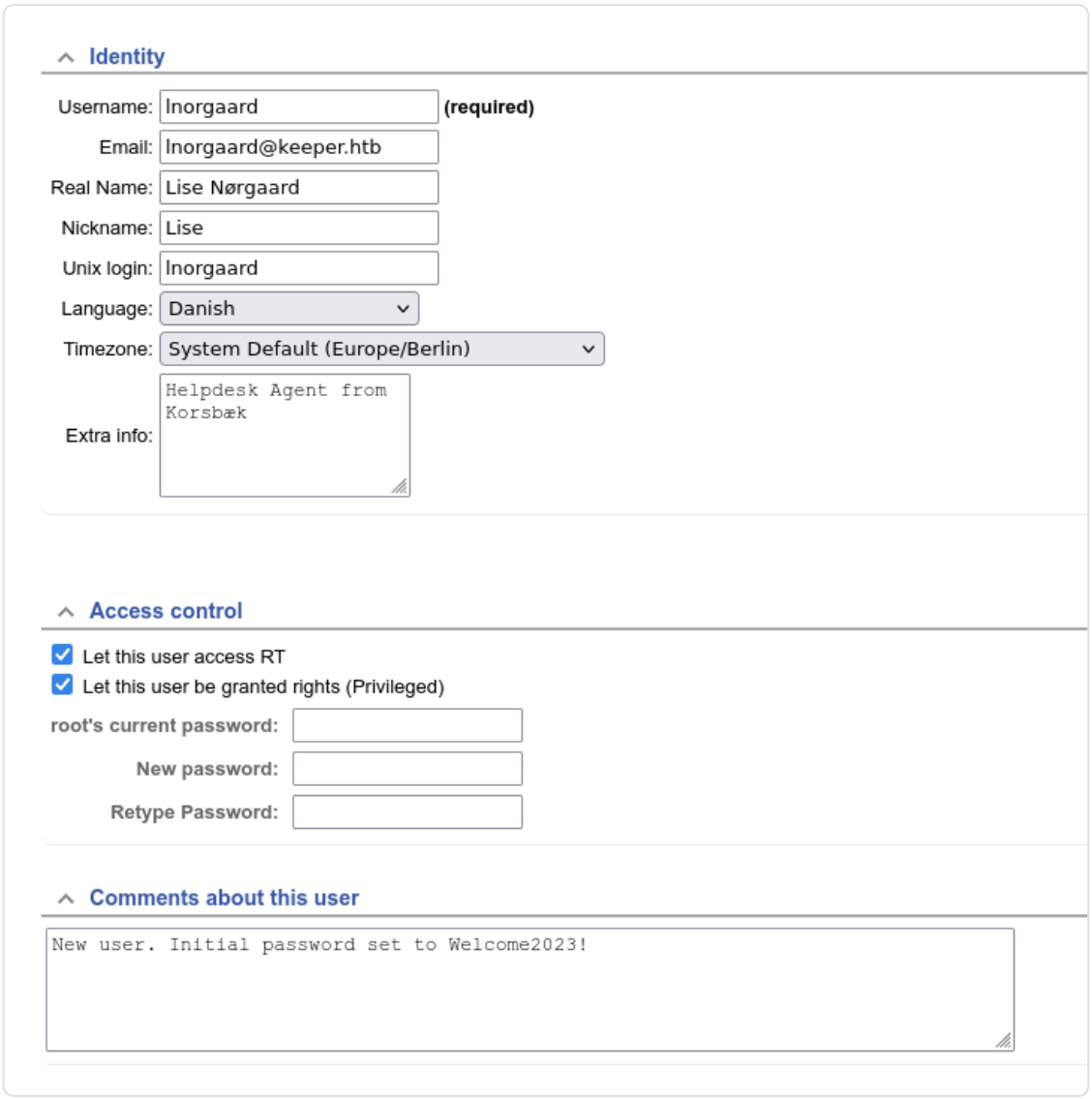
```
22/tcp open  ssh   OpenSSH 8.9p1 Ubuntu 3ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp open  http  nginx 1.18.0 (Ubuntu)
```

3. Foothold

`keeper.htb` and its `tickets.keeper.htb` vhost are registered in `/etc/hosts`. The ticketing subdomain runs **Request Tracker (RT)**, a well-known open-source ticketing system, identifiable from its login page. RT ships with a default administrator account that is frequently left unchanged after install:

```
root : password
```

Those credentials work and grant full admin access to the RT instance. Browsing to **Admin > Users** surfaces an entry for `lnorgaard` (real name Lise Nørgaard, listed as a "Helpdesk Agent from Korsbæk" with the language set to Danish), whose comments field leaks the account's initial password in plaintext:



RT's Admin > Users edit page for `lnorgaard`, with the Unix login and a comment leaking the initial password `Welcome2023!`.

```
lnorgaard : Welcome2023!
```

SSH access with those credentials succeeds, giving the user flag plus a ZIP archive containing a KeePass backup: a `.kdbx` database and a captured **process memory dump** of the running KeePass application (`KeePassDumpFull.dmp`).

4. Privilege escalation

KeePass master-password recovery: CVE-2023-32784

The KeePass database requires a master password that is not known. KeePass versions before 2.54 are vulnerable to **CVE-2023-32784**: the custom password-entry textbox used by KeePass leaves residual data behind in process memory for almost every character typed into it, with the one exception of the very first character.

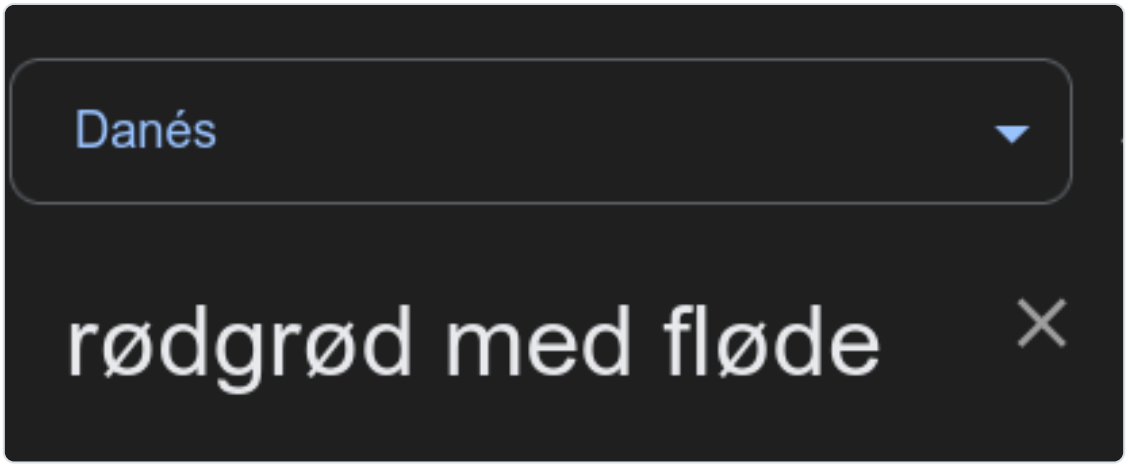
Running `keepass-password-dumper` (.NET 7 required) against the leaked memory dump:

```
dotnet run KeePassDumpFull.dmp
```

produces a list of character candidates for each position:

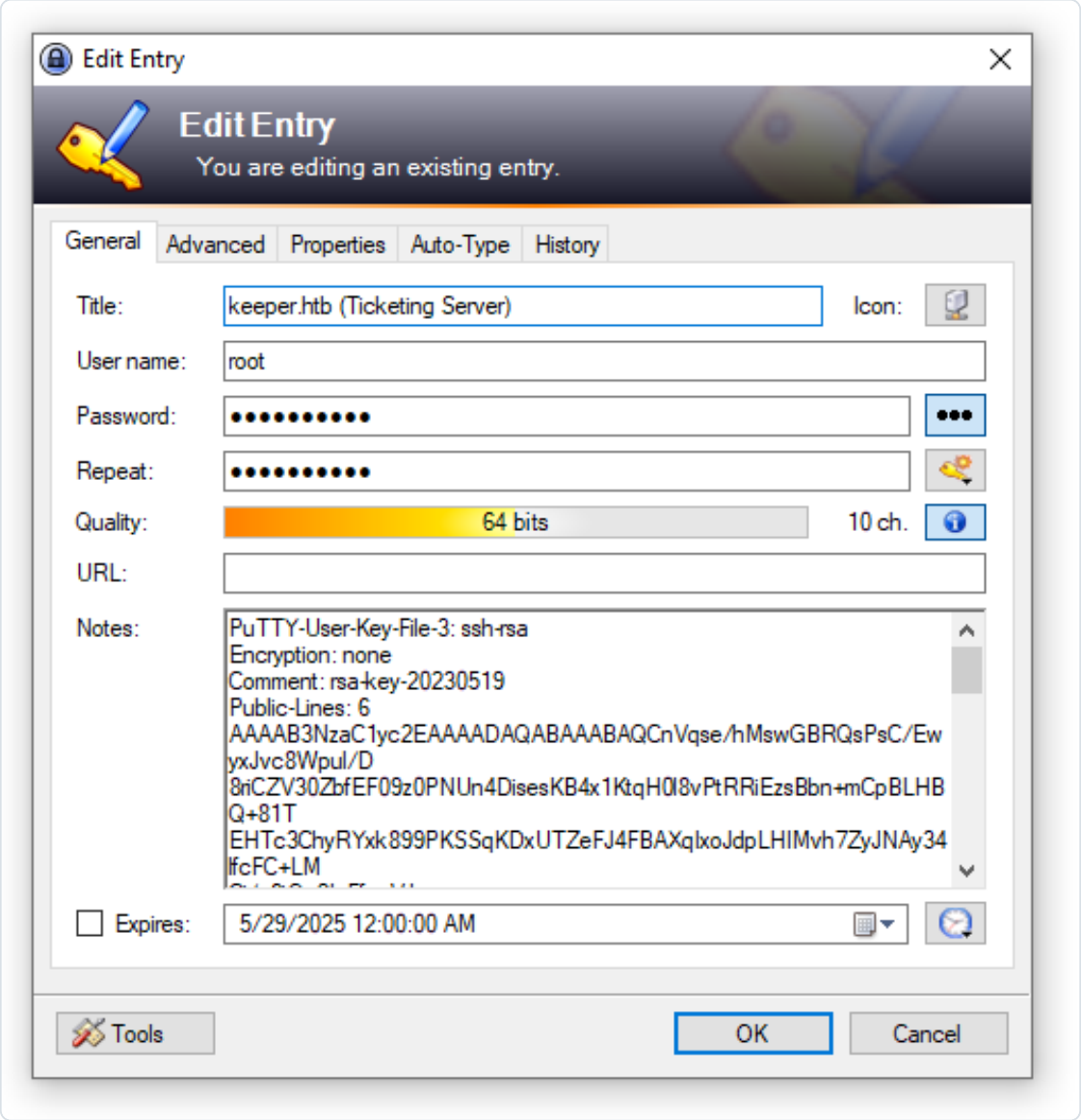
```
Combined: ●{ø, Ï, ,, l, `, -, ', ], §, A, I, :, =, _, c, M}dgrød med fløde
```

Positions 3 through 17 resolve cleanly to `dgrød med fløde`, position 1 is entirely unrecoverable (the CVE's known limitation), and position 2 offers 16 candidates, `ø` among them. The RT user record already flagged `lnorgaard` as Danish, and the partial string strongly suggests the well-known Danish tongue-twister **"rødgrød med fløde"** ("red groats with cream", a notoriously hard phrase for non-native speakers and a common informal fluency test). Both missing characters, `r` and `ø`, line up with the recovered candidates:



Confirming the guessed phrase in Google Translate: `rødgrød med fløde`*, set to Danish.*

Using `rødgrød med fløde` as the master password unlocks the KeePass database. A single entry, `keeper.htb (Ticketing Server)`, stores a username of `root` and a **PuTTY-format** private key pasted into its Notes field:



The unlocked `keeper.htb (Ticketing Server)` entry, with a PuTTY-format private key for `root` in its Notes field.

The key is converted from PuTTY's `.ppk` format to OpenSSH and used to connect directly as root:

```
puttygen pass.rsa -O private-openssh -o id_rsa
ssh root@<IP> -i id_rsa
```

This gives a root shell and the root flag.

5. Flags

USER.TXT	ROOT.TXT
835a•••••••••••••	48e1•••••••••••••

6. Notes & lessons

- **New techniques:** recovering a KeePass master password straight from a process memory dump via CVE-2023-32784, and converting a PuTTY private key to OpenSSH format for direct use.
- **Interesting:** the attack chain never needs to crack a conventional password hash. The "crack" here is a memory-forensics flaw specific to KeePass's UI widget, combined with an OSINT-style clue (the target's language field in RT) to resolve the one or two characters the CVE alone cannot recover.

7. References

- CVE-2023-32784: KeePass master password recovery from memory
- vdohney/keepass-password-dumper (PoC)